

CCS6224

Network Security

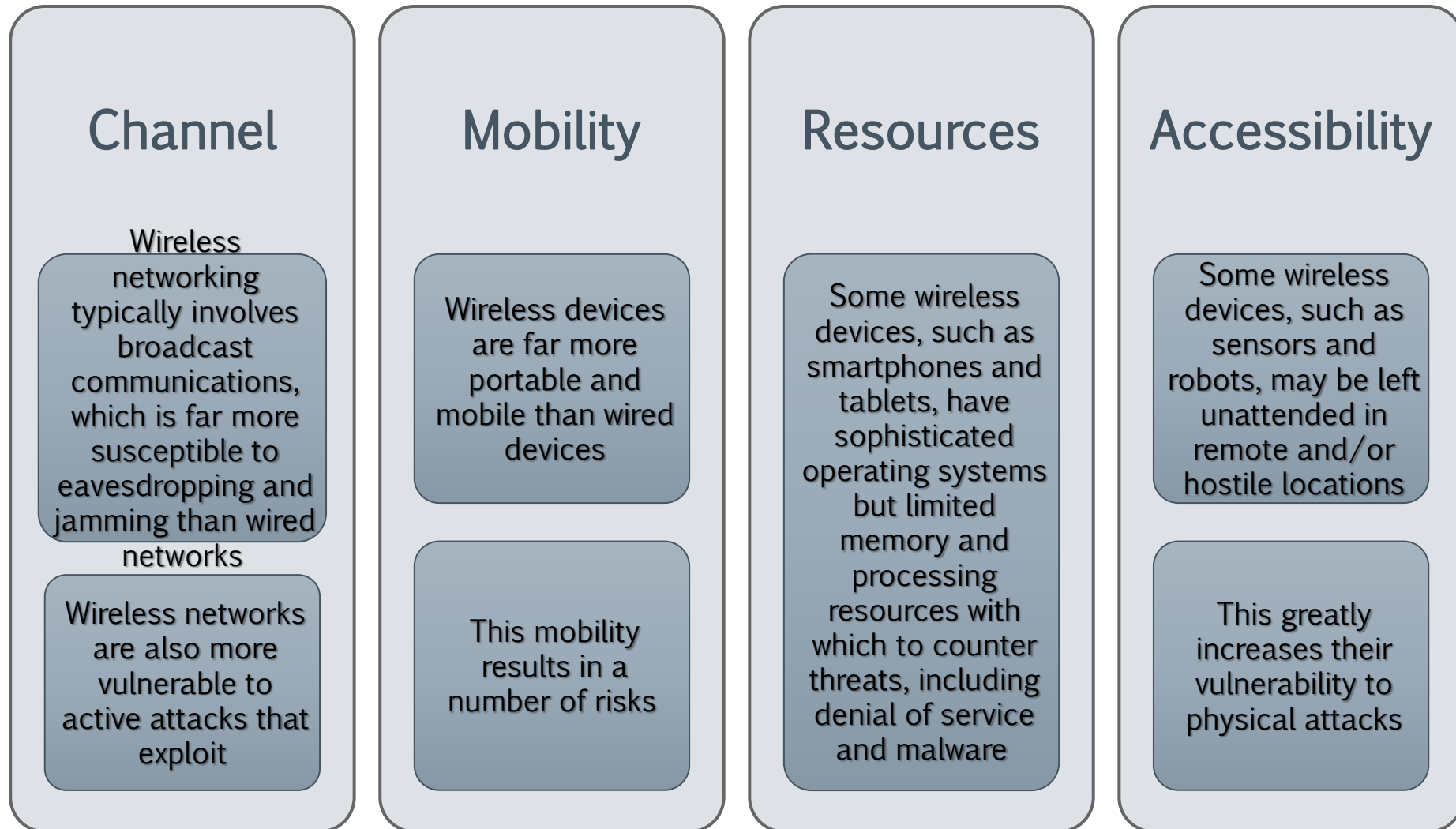
Lecture 9
Wireless Network Security

Outline

- › Wireless Security
- › Mobile Device Security
- › IEEE 802.11 Wireless LAN Overview
- › IEEE 802.11i Wireless LAN Security

Wireless Security

- › Some of the key factors contributing to the higher security risk of wireless networks compared to wired networks include:



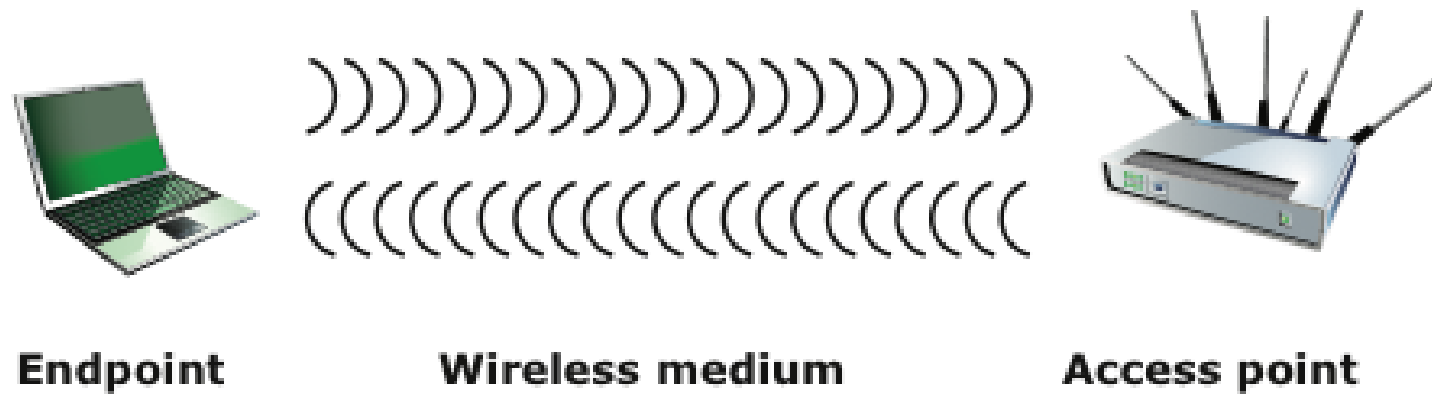


Figure 18.1 Wireless Networking Components

Wireless Network Threats

› **Accidental association**

- Company wireless LANs in close proximity may create overlapping transmission ranges
- A user intending to connect to one LAN may unintentionally lock on to a wireless access point from a neighboring network

› **Malicious association**

- In this situation, a wireless device is configured to appear to be a legitimate access point, enabling the operator to steal passwords from legitimate users and then penetrate a wired network through a legitimate wireless access point

› **Ad hoc networks**

- These are peer-to-peer networks between wireless computers with no access point between them
- Such networks can pose a security threat due to a lack of a central point of control

› **Nontraditional networks**

- Personal network Bluetooth devices, barcode readers, and handheld PDAs pose a security risk in terms of both eavesdropping and spoofing

Wireless Network Threats

› Identity theft (MAC spoofing)

- This occurs when an attacker is able to eavesdrop on network traffic and identify the MAC address of a computer with network privileges

› Man-in-the-middle attacks

- This attack involves persuading a user and an access point to believe that they are talking to each other when in fact the communication is going through an intermediate attacking device
- Wireless networks are particularly vulnerable to such attacks

› Denial of service (DoS)

- This attack occurs when an attacker continually bombards a wireless access point or some other accessible wireless port with various protocol messages designed to consume system resources
- The wireless environment lends itself to this type of attack because it is so easy for the attacker to direct multiple wireless messages at the target

› Network injection

- This attack targets wireless access points that are exposed to nonfiltered network traffic, such as routing protocol messages or network management messages

Securing Wireless Transmissions

- › The principal threats to wireless transmission are eavesdropping, altering or inserting messages, and disruption
- › To deal with eavesdropping, two types of countermeasures are appropriate:
 - Signal-hiding techniques
 - › Turn off SSID broadcasting by wireless access points
 - › Assign cryptic names to SSIDs
 - › Reduce signal strength to the lowest level that still provides requisite coverage
 - › Locate wireless access points in the interior of the building, away from windows and exterior walls
 - Encryption
 - › Is effective against eavesdropping to the extent that the encryption keys are secured

Securing Wireless Access Points

- › The main threat involving wireless access points is **unauthorized access to the network**
- › The principal approach for preventing such access is the IEEE 802.1x standard for port-based network access control
 - The standard provides an authentication mechanism for devices wishing to attach to a LAN or wireless network
 - The use of 802.1x can prevent rogue access points and other unauthorized devices from becoming insecure backdoors

Securing Wireless Networks

Use encryption

Use antivirus, anti-spyware software, and a firewall

Turn off identifier broadcasting

Change the identifier on your router from the default

Change your router's pre-set password for administration

Allow only specific computers to access your wireless network

Mobile Device Security

- › Mobile devices have become an essential element for organizations as part of the overall network infrastructure
- › Prior to the widespread use of smartphones, network security was based upon clearly defined perimeters that separated trusted internal networks from the untrusted Internet
- › Due to massive changes, an organization's networks must now accommodate:
 - Growing use of new devices
 - Cloud-based applications
 - De-perimeterization
 - External business requirements



Security Threats

› 7 Major security concerns for mobile devices:

1. Lack of Physical Security Controls

Mobile device is required to remain on premises, the user may move the device within the organization between secure and non-secured locations. theft and tampering are realistic threats. A malicious party may attempt to recover sensitive data from the device itself. The party may use the device to gain access to the organization's resources.

2. Use of Untrusted Mobile Devices

In addition to company-issued and company-controlled mobile devices, virtually all employees will have personal smartphones and/or tablets. The organization must assume that these devices are not trustworthy.

3. Use of Untrusted Networks

If a mobile device is used on premises, it can connect to organization resources over the organization's own in-house wireless networks. Thus, traffic that includes an off-premises segment is potentially susceptible to eavesdropping or man-in-the-middle types of attacks.

Security Threats (cont.)

4. Use of Applications Created by Unknown Parties

By design, it is easy to find and install third-party applications on mobile devices. This poses the obvious risk of installing malicious software.

5. Interaction with Other Systems

Unless an organization has control of all the devices involved in synchronization, there is considerable risk of the organization's data being stored in an unsecured location, plus the risk of the introduction of malware.

6. Use of Untrusted Contents

Mobile devices may access and use content that other computing devices do not encounter.

7. Use of Location Services

The GPS service, it creates security risks. An attacker can use the location information to determine where the device and user are located, which may be of use to the attacker.

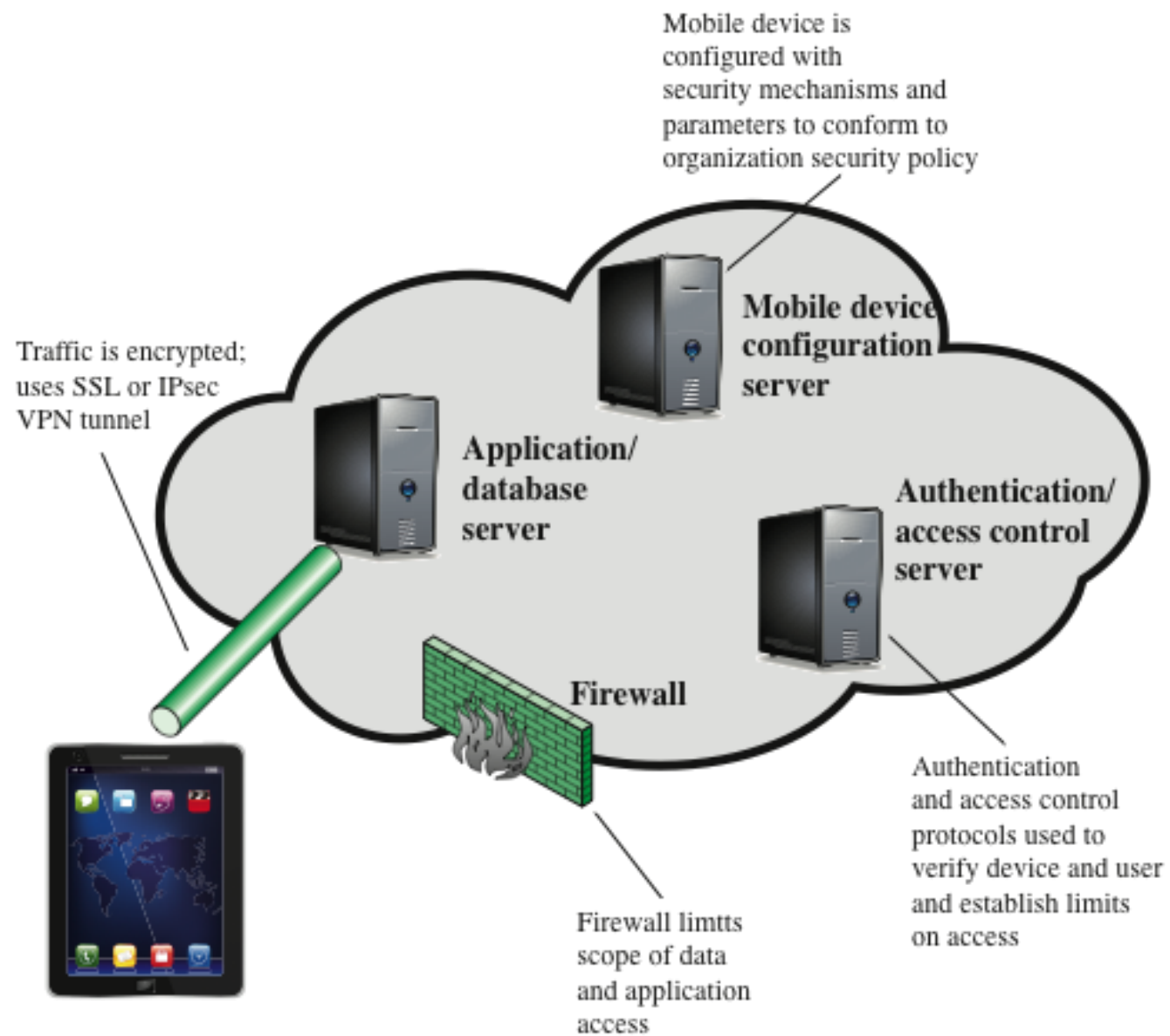


Figure 18.2 Mobile Device Security Elements

IEEE 802.11 Wireless LAN Overview

- › IEEE 802 is a committee that has developed standards for a wide range of local area networks (LANs)
- › In 1990 the IEEE 802 Committee formed a new working group, IEEE 802.11, with a charter to develop a protocol and transmission specifications for wireless LANs (WLANs)
- › Since that time, the demand for WLANs at different frequencies and data rates has exploded

Table 18.1

IEEE 802.11 Terminology

Access point (AP)	Any entity that has station functionality and provides access to the distribution system via the wireless medium for associated stations.
Basic service set (BSS)	A set of stations controlled by a single coordination function.
Coordination function	The logical function that determines when a station operating within a BSS is permitted to transmit and may be able to receive PDUs.
Distribution system (DS)	A system used to interconnect a set of BSSs and integrated LANs to create an ESS.
Extended service set (ESS)	A set of one or more interconnected BSSs and integrated LANs that appear as a single BSS to the LLC layer at any station associated with one of these BSSs.
MAC protocol data unit (MPDU)	The unit of data exchanged between two peer MAC entities using the services of the physical layer.
MAC service data unit (MSDU)	Information that is delivered as a unit between MAC users.
Station	Any device that contains an IEEE 802.11 conformant MAC and physical layer.

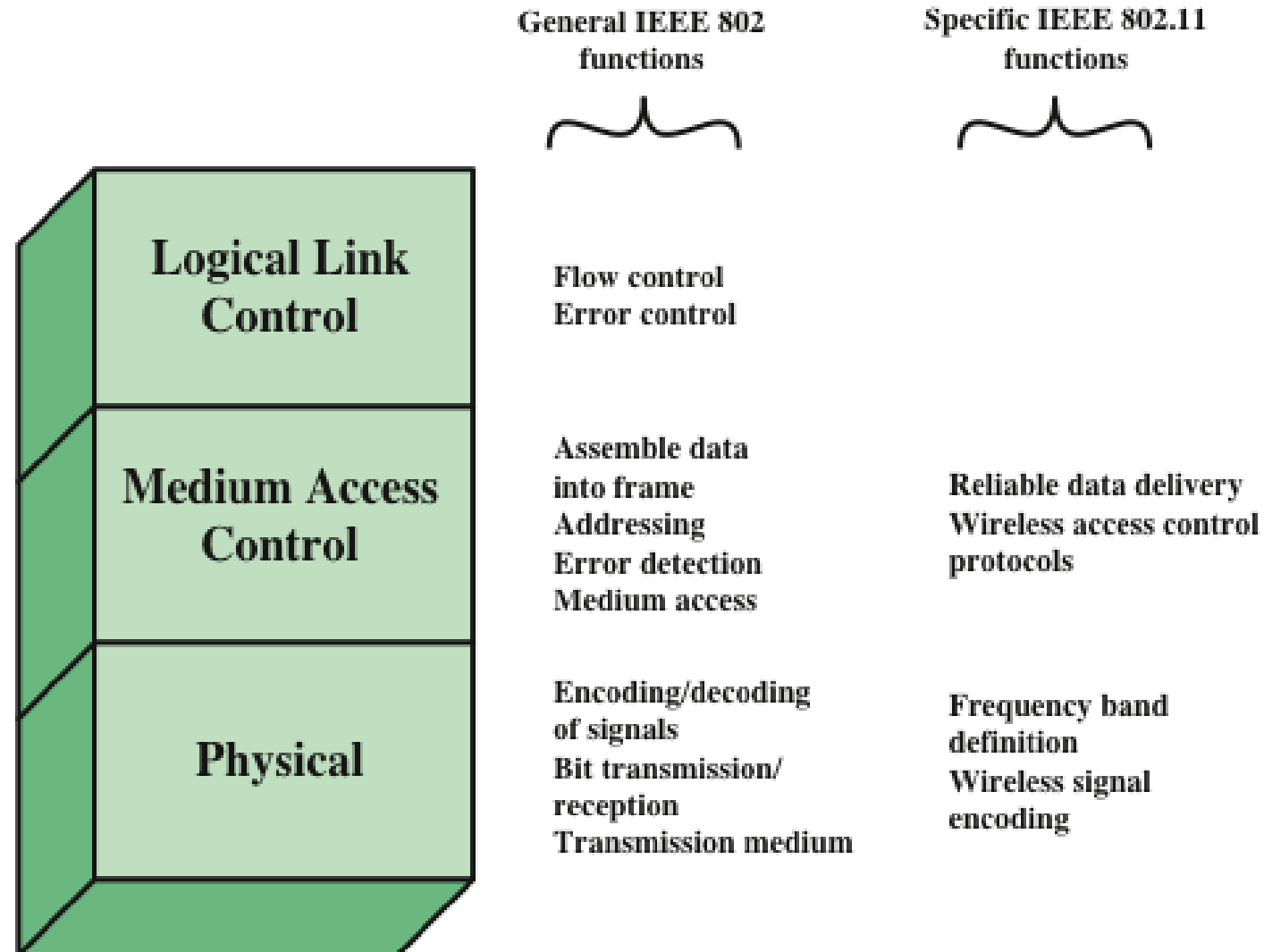


Figure 18.3 IEEE 802.11 Protocol Stack

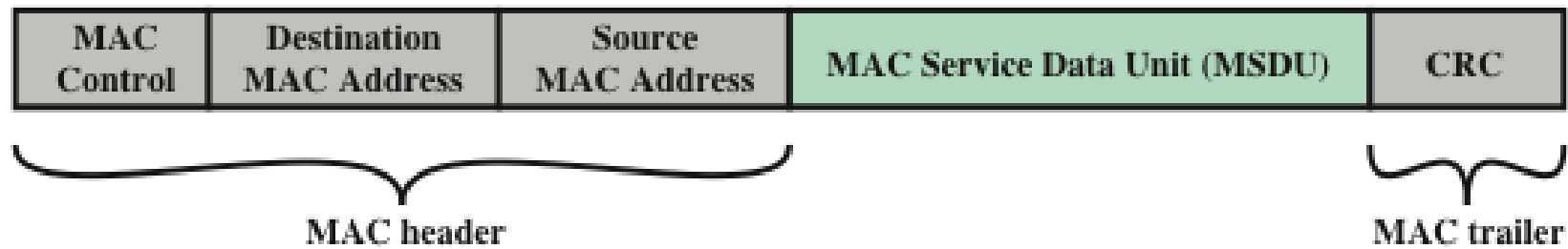


Figure 18.4 General IEEE 802 MPDU Format

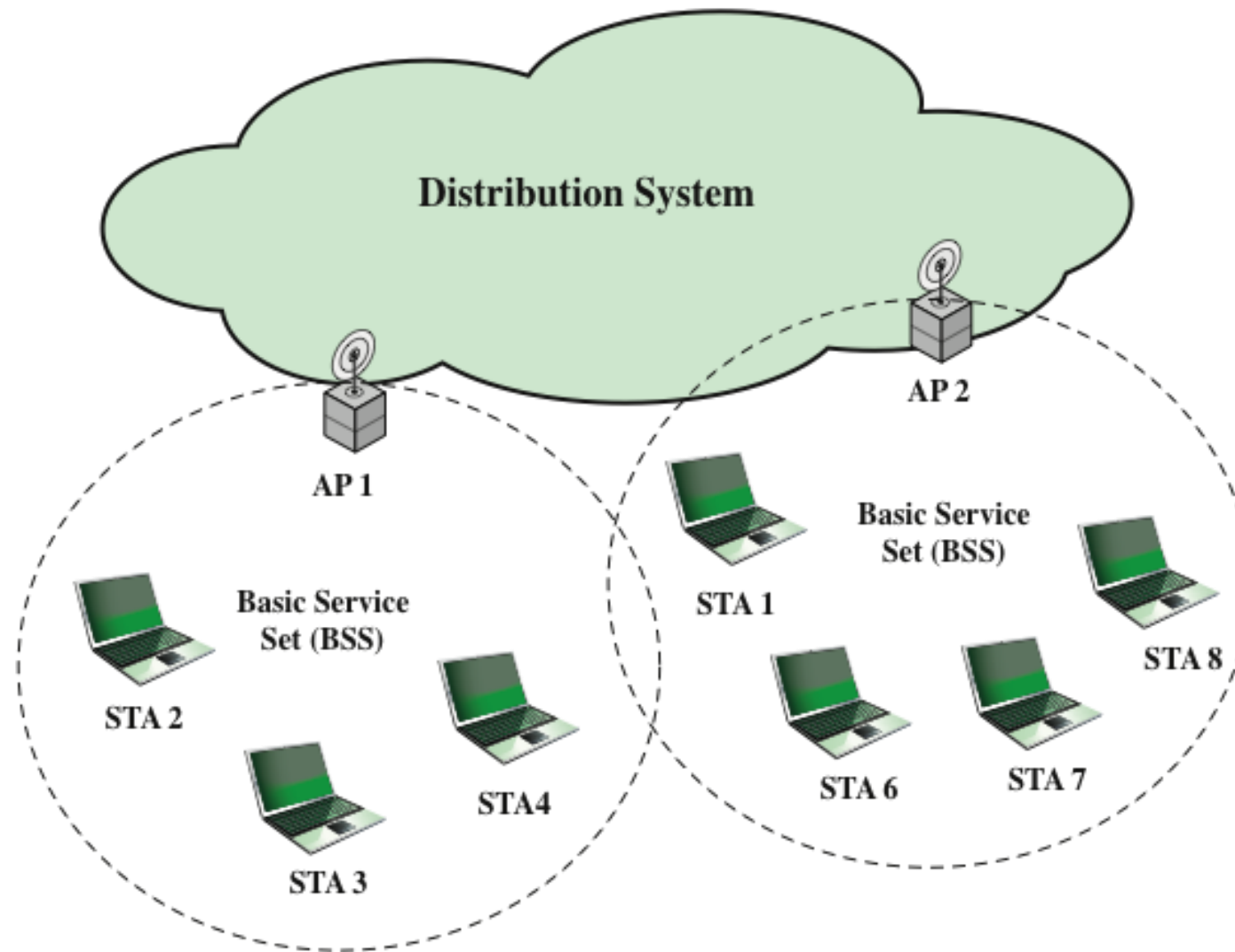
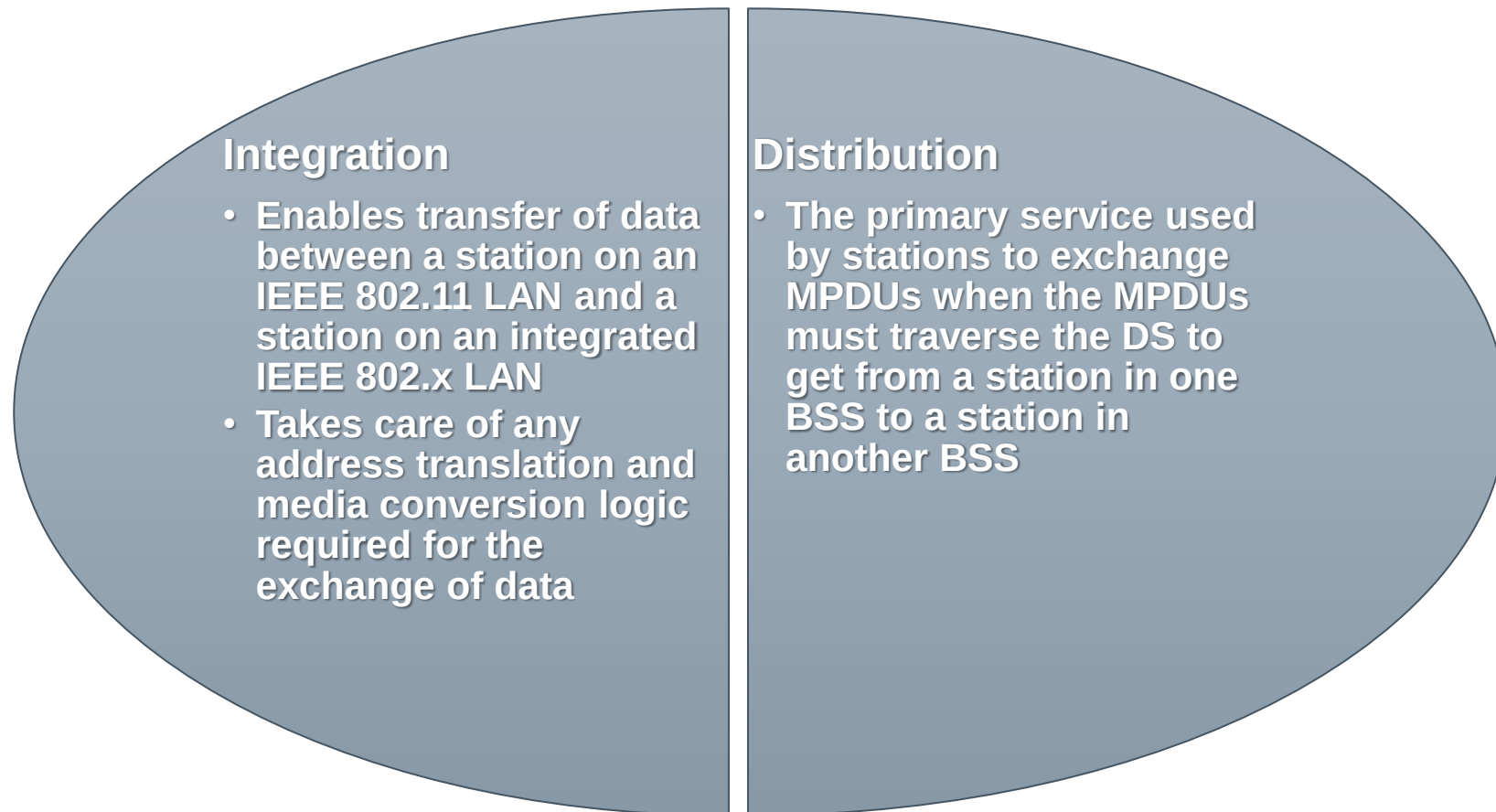


Figure 18.5 IEEE 802.11 Extended Service Set

Distribution of Messages Within a DS

- › The two services involved with the distribution of messages within a DS are:



Association-Related Services

› Transition types based on mobility:

No transition

- A station of this type is either stationary or moves only within the direct communication range of the communicating stations of a single BSS

BSS transition

- This is defined as a station movement from one BSS to another BSS within the same ESS
- In this case, delivery of data to the station requires that the addressing capability be able to recognize the new location of the station

ESS transition

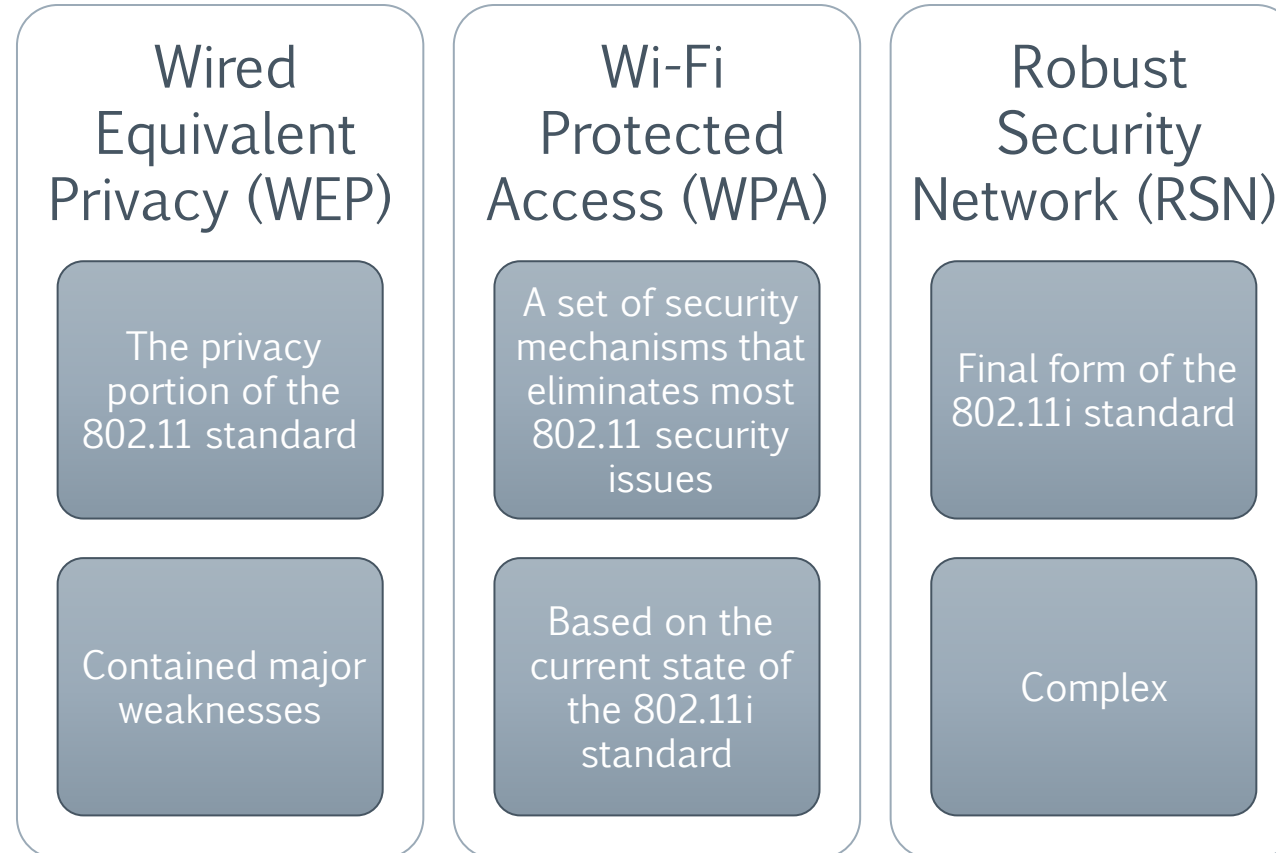
- This is defined as a station movement from a BSS in one ESS to a BSS within another ESS
- Maintenance of upper-layer connections supported by 802.11 cannot be guaranteed
- Disruption of service is likely to occur

Association-Related Services

- › To deliver a message within a DS, the distribution service needs to know the identity of the AP to which the message should be delivered in order for that message to reach the destination station
- › Three services relate to a station maintaining an association with the AP within its current BSS:
 - Association
 - › Establishes an initial association between a station and an AP
 - Reassociation
 - › Enables an established association to be transferred from one AP to another, allowing a mobile station to move from one BSS to another
 - Disassociation
 - › A notification from either a station or an AP that an existing association is terminated

IEEE 802.11i Wireless LAN Security

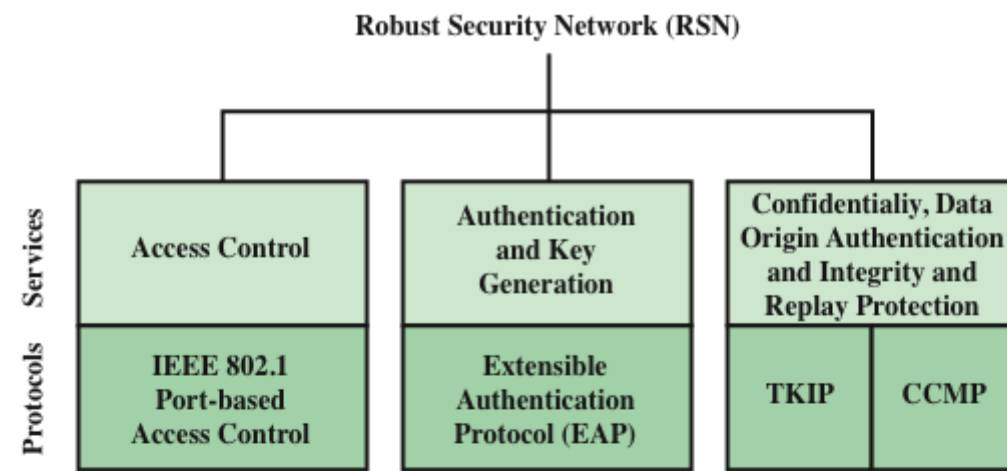
- › There is an increased need for robust security services and mechanisms for wireless LANs



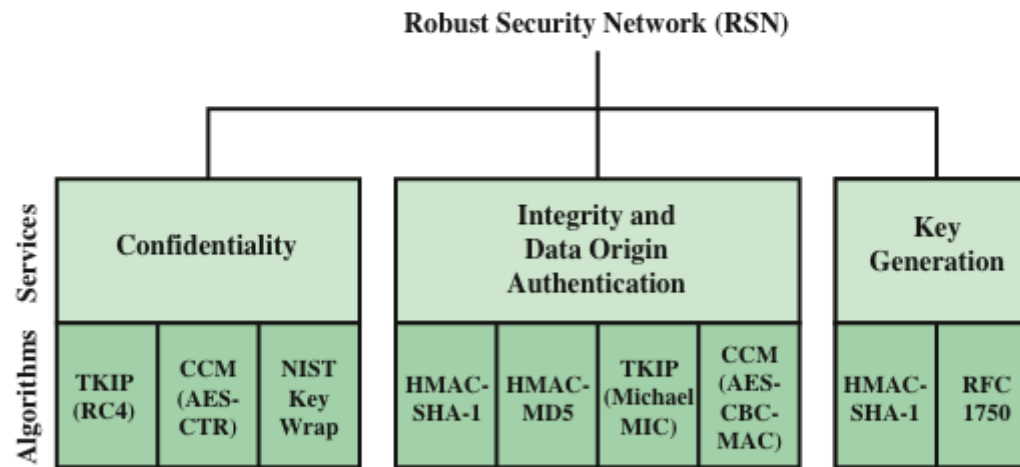
IEEE 802.11i Wireless LAN Security

› 802.11i RSN Security Services

- **Authentication:** Mutual recognition between the user and the AS using the protocol and defines a temporary key generation used between the client and the AP between the wireless link.
- **Access control:** Use the authentication function, will be done through the proper message routing and key exchange. The implementation of this feature, using a variety of authentication protocols.
- **Privacy with message integrity:** Encrypting the message with the integrity code can be confirmed that the data has not changed the data in the MAC layer.



(a) Services and Protocols



(b) Cryptographic Algorithms

CBC-MAC = Cipher Block Chaining Message Authentication Code (MAC)
 CCM = Counter Mode with Cipher Block Chaining Message Authentication Code
 CCMP = Counter Mode with Cipher Block Chaining MAC Protocol
 TKIP = Temporal Key Integrity Protocol

Figure 18.6 Elements of IEEE 802.11i

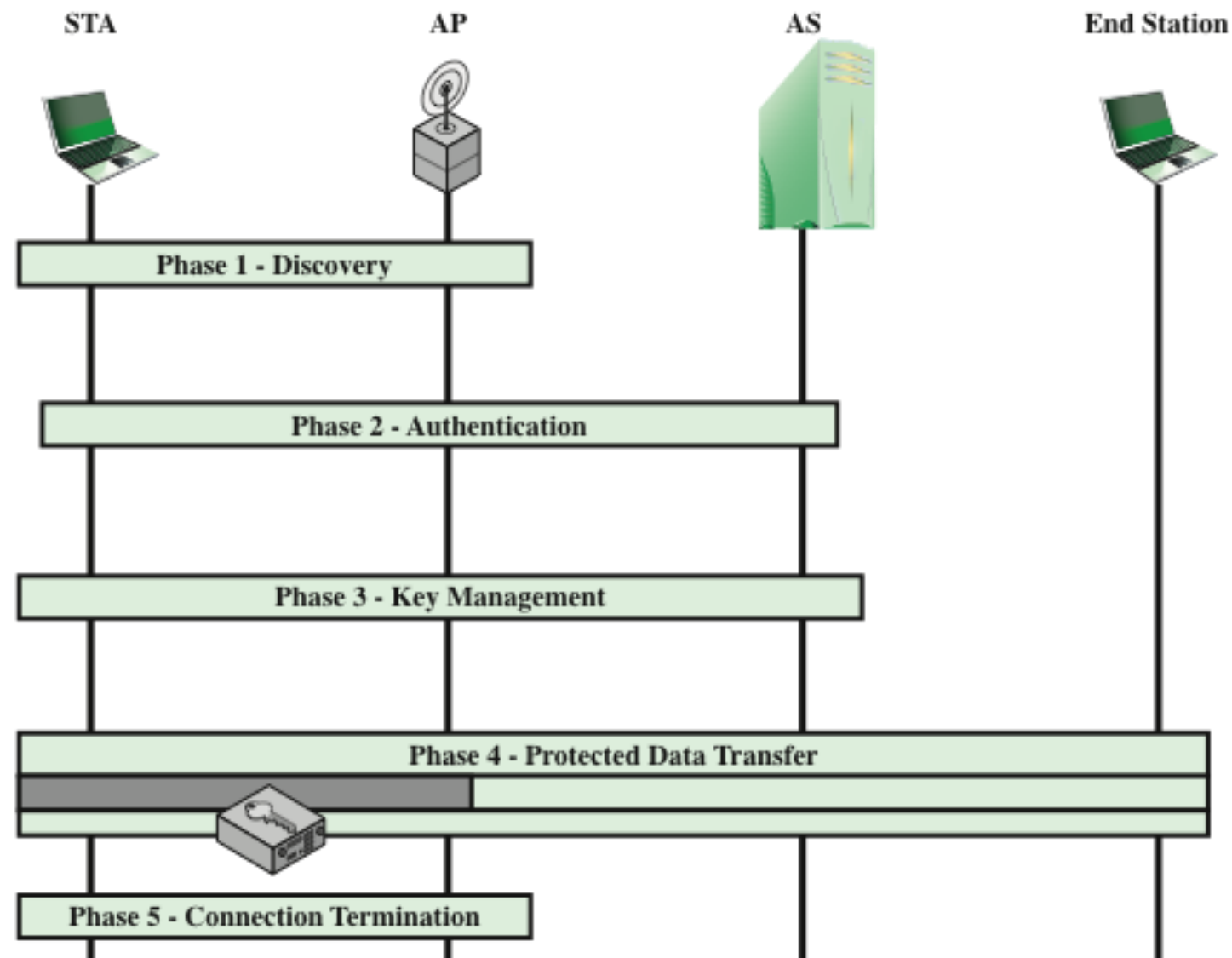


Figure 18.7 IEEE 802.11i Phases of Operation

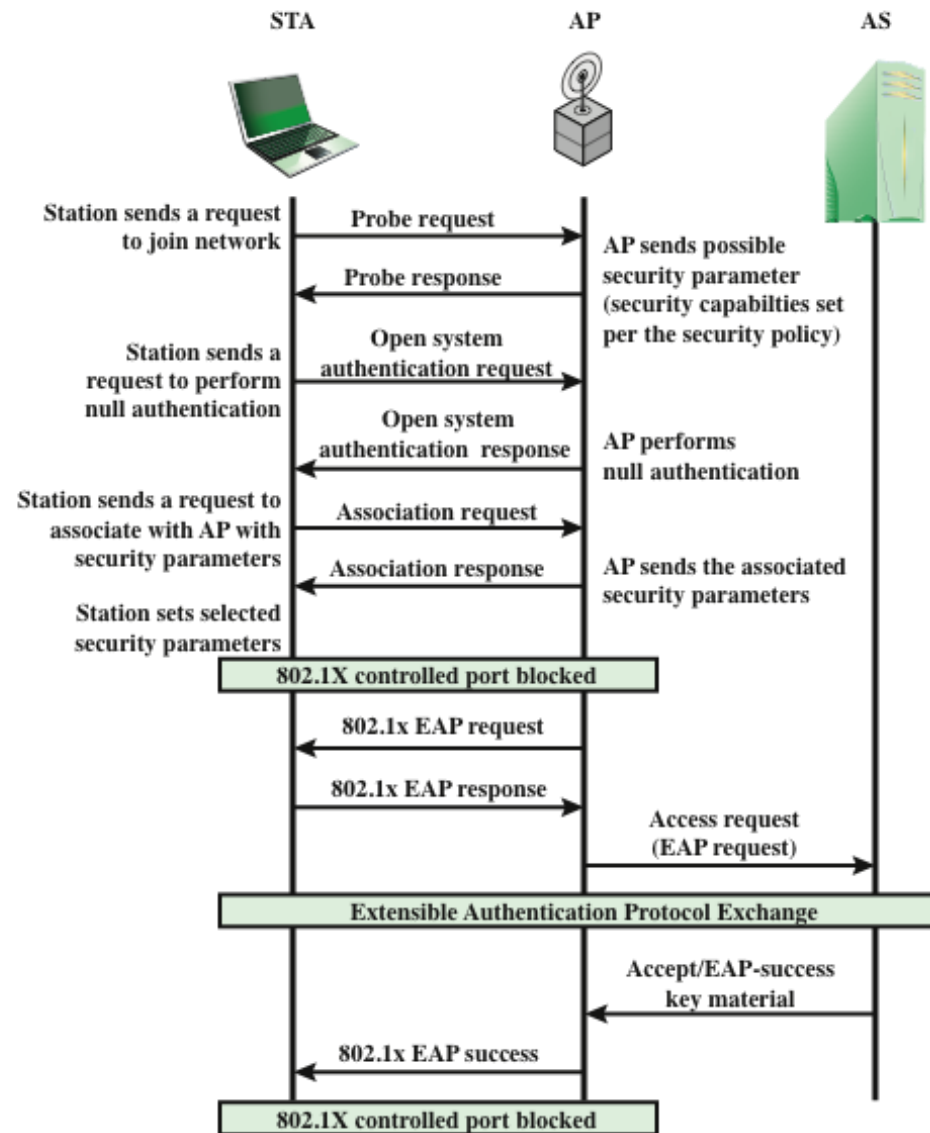
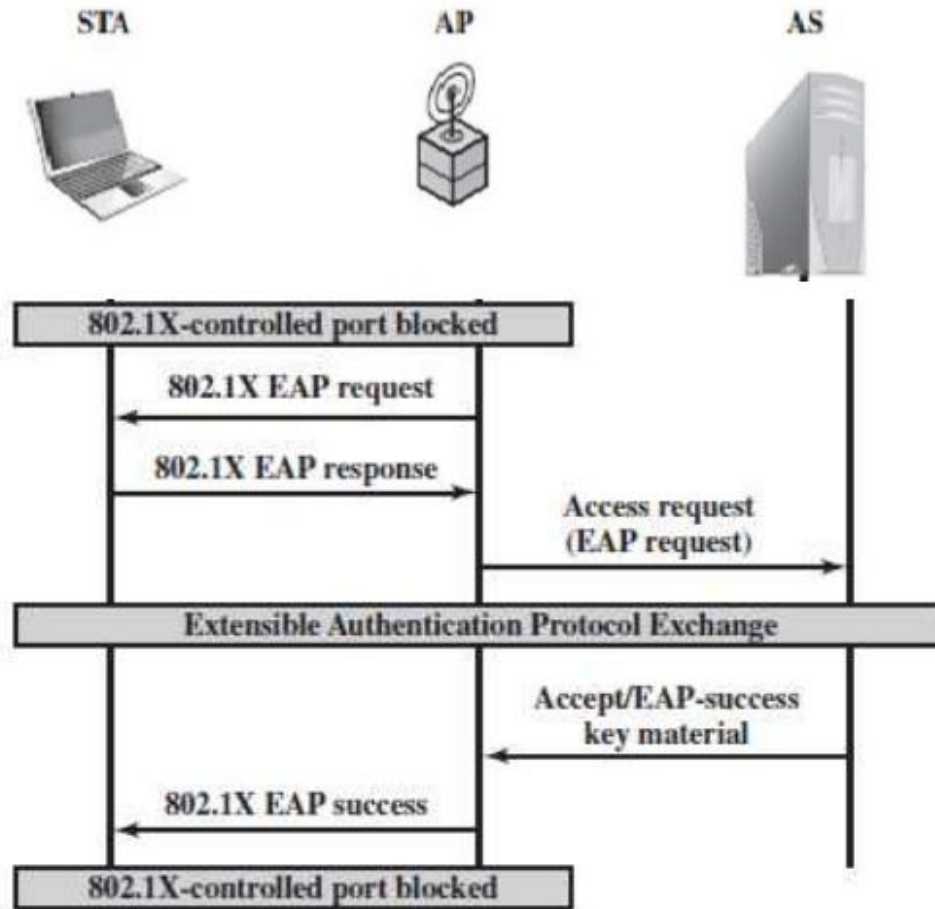


Figure 18.8 IEEE 802.11i Phases of Operation: Capability Discovery, Authentication, and Association

Discovery Phase

- › The Discovery phase determines the technology used in the following areas.
 - Confidentiality Integrity Protocol MPDU
 - Authentication Method
 - Cryptographic key management scheme
- › Encryption options are as follows for the confidentiality and integrity protection.
 - WEP
 - TKIP
 - CCMP
- › MPDU Exchange.
 - network and security features
 - Open System Authentication
 - Association

Authentication Phase



- › Authentication step of performing authentication between a station and AS.
- › Allow an authenticated Station use the network.
- › Certification process step is composed of three steps:
 - Connect to AS
 - EAP Exchange
 - Secure Key Delivery

Authentication Phase

› Connect to AS

- Station sends a request to their AP. AP is a response to the received request, and transmits the access request to the AS.

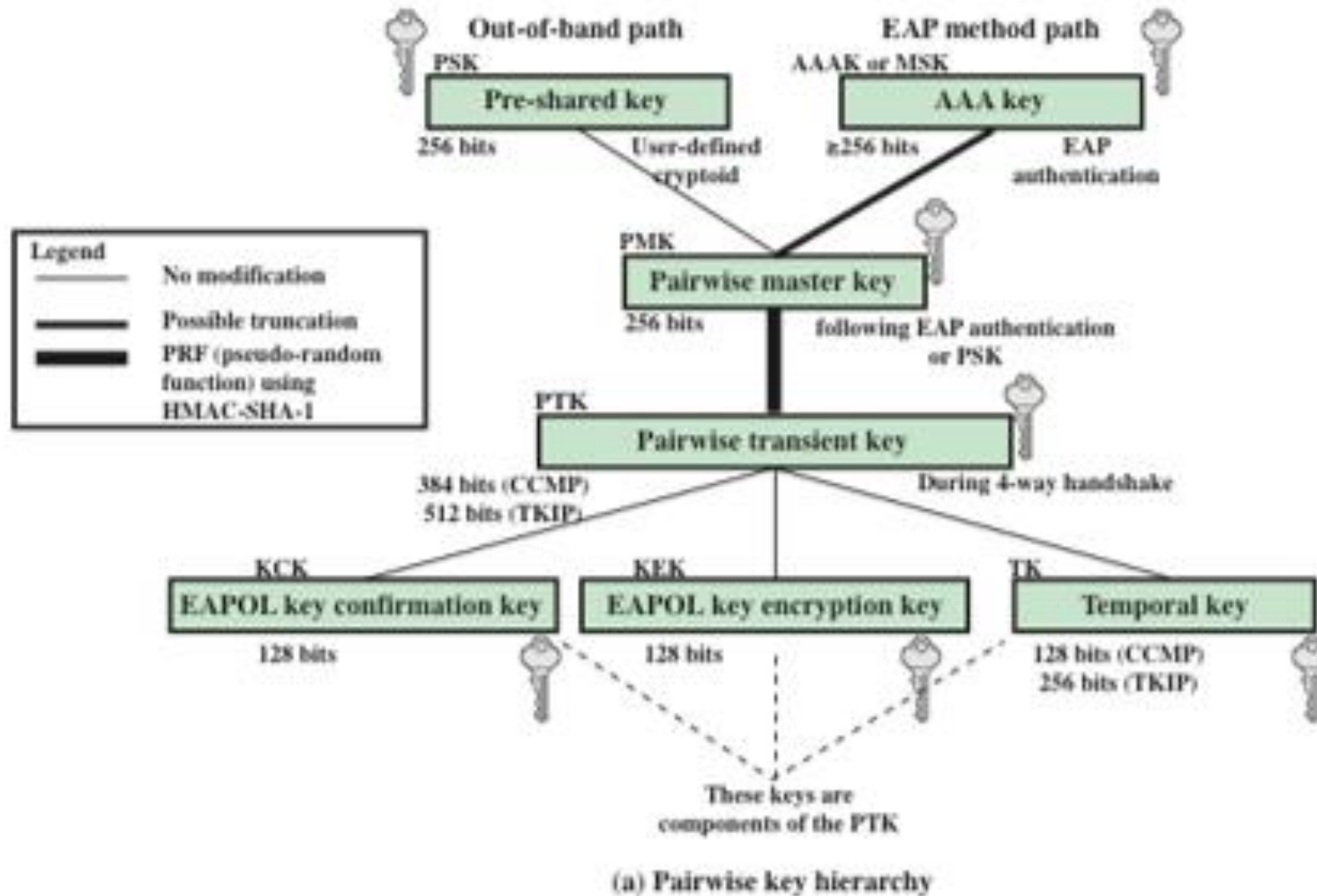
› EAP Exchange

- Do the mutual authentication between the Station and the AS

› Secure Key Delivery

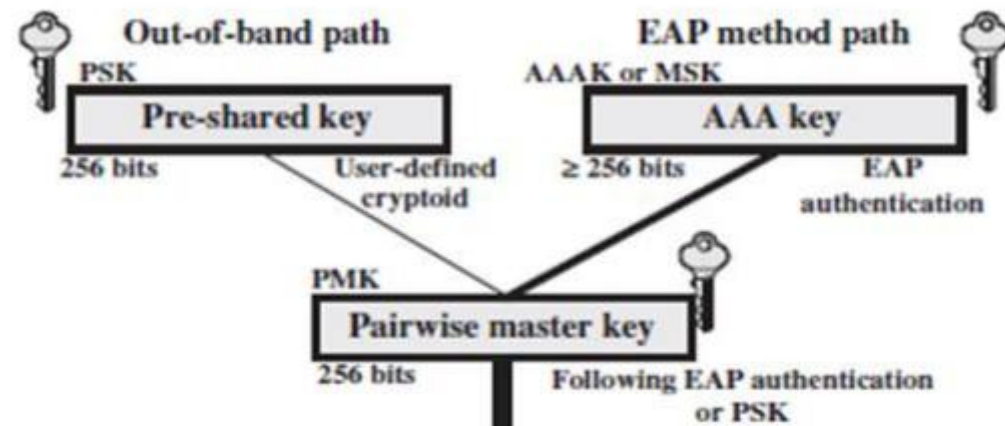
- The AS generates a Master Session Key (MSK) after mutual authentication and sent to the Station. Master keys are transferred to the Station through the AP

Key Management Phase



Key Management Phase

- › The key management phase, various encryption key is generated and being distributed Station
- › Pairwise key pair are commonly used for communication between the Station and the AP
- › The top layer has two kinds of keys:
 - PSK is AP and Station shared key to the dictionary
 - MSK (aka AAK) is generated during the authentication phase is different from the generation method according to the authentication protocol



Pairwise Keys

› Pairwise master key (PMK)

- Derived from the master key
- If a PSK is used, then the PSK is used as the PMK; if a MSK is used, then the PMK is derived from the MSK by truncation

› Pairwise transient key (PTK)

- Consists of three keys to be used for communication between a STA and AP after they have been mutually authenticated
- Using the STA and AP addresses in the generation of the PTK provides protection against session hijacking and impersonation; using nonces provides additional random keying material

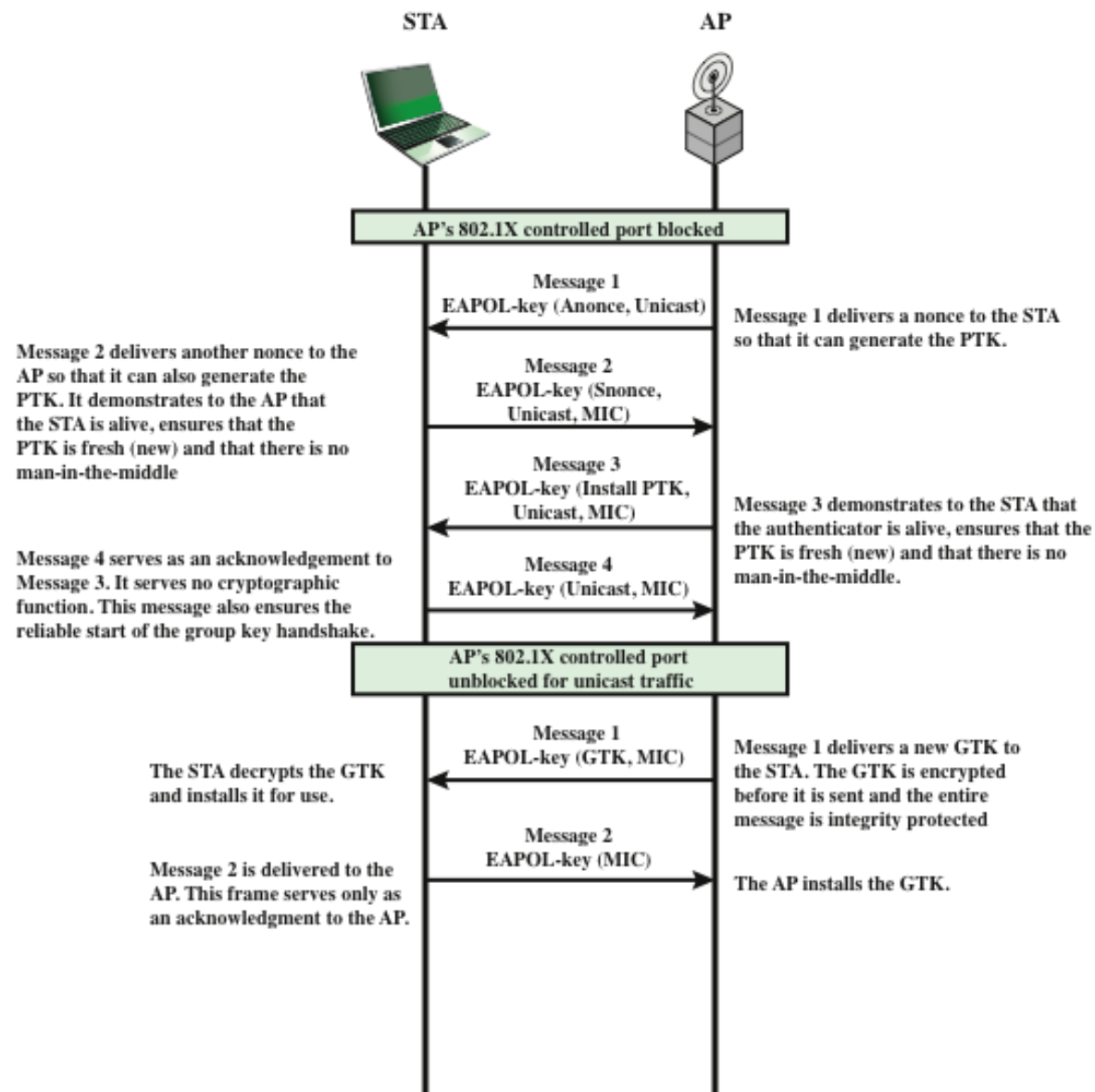


3 Parts of PTK

- › **EAP Over LAN (EAPOL) Key Confirmation Key (EAPOL-KCK)**
 - Supports the integrity and data origin authenticity of STA-to-AP control frames during operational setup of an RSN
 - It also performs an access control function: proof-of-possession of the PMK
 - An entity that possesses the PMK is authorized to use the link
- › **EAPOL Key Encryption Key (EAPOL-KEK)**
 - Protects the confidentiality of keys and other data during some RSN association procedures
- › **Temporary (TK)**
 - Provides the actual protection for user traffic

Group Keys

- › Group keys are used for multicast communication in which one STA sends MPDUs to multiple STAs
 - **Group master key (GMK)**
 - › Key-generating key used with other inputs to derive the GTK
 - **Group temporal key (GTK)**
 - › Generated by the AP and transmitted to its associated STAs
 - › IEEE 802.11i requires that its value is computationally indistinguishable from random
 - › Distributed securely using the pairwise keys that are already established
 - › Is changed every time a device leaves the network



**Figure 18.10 IEEE 802.11i Phases of Operation:
Four-Way Handshake and Group Key Handshake**

Protected Data Transfer Phase

- › IEEE 802.11i defines two schemes for protecting data transmitted in 802.11 MPDUs:
 - Temporal Key Integrity Protocol (TKIP)
 - › Designed to require only software changes to devices that are implemented with WEP
 - › Provides two services:
 - Message integrity
 - Data confidentiality
 - Counter Mode-CBC MAC Protocol (CCMP)
 - › Intended for newer IEEE 802.11 devices that are equipped with the hardware to support this scheme
 - › Provides two services:
 - Message integrity
 - Data confidentiality